

57 DAYS.
80,000 ENDPOINTS.
€100 MILLION.

The HSE Ireland Ransomware catastrophe. Replicated, analyzed, and
defeated inside our active defense SOC lab.

| THE CHALLENGE

The HSE Catastrophe

Impact: Ireland's entire healthcare system went dark.

Casualties: Cancer treatments postponed, emergency rooms on paper, ambulances rerouted.

Attack Vector: Not a smash-and-grab, but 57 days of slow, quiet preparation beginning with one infected Excel file.

Our Mission Goal

The Question: Could we detect and stop what they couldn't see?

The Answer: Yes. By designing a highly resilient, isolated, baseline-monitored SOC sandbox representing the target ecosystem.

The Strategy: 5 Virtual Machines, a customized Wazuh SIEM stack, and targeted telemetry pipelines.

THE 57-DAY SILENT KILL CHAIN



OUR LAB ARCHITECTURE

WS-EMP01 (Patient Zero)

Standard Windows 10 workstation. Connected via Tailscale VPN to simulate a split-tunnel remote worker.

DC01 (Domain Controller)

Active Directory Controller, DNS Authority. The ultimate crown jewel target of the domain.

FS01 (File Server)

Hosts departmental shares (Finance, Radiology, Appointments, IT Support). Prime target for exfiltration.

ATTACK01 (Kali Linux)

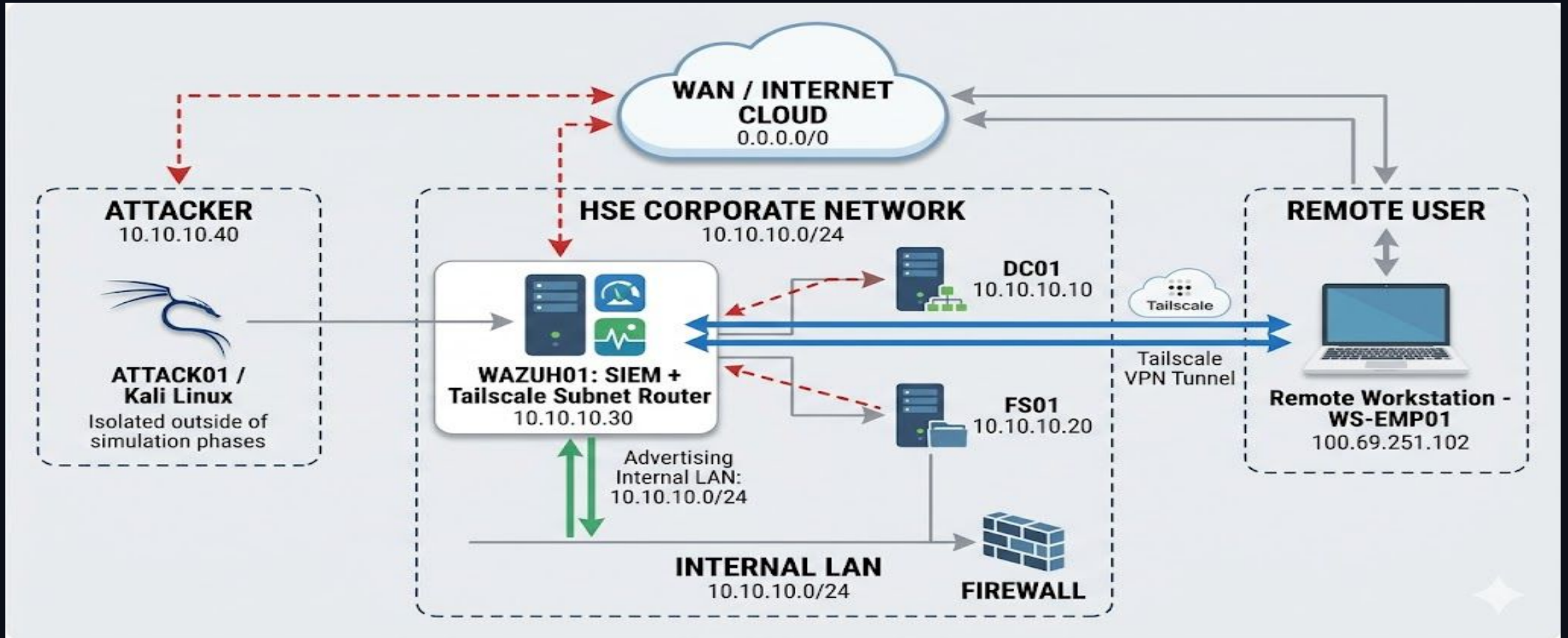
Isolated adversary system running red team frameworks and malicious payloads.

WAZUH01 (SIEM Brain & Router)

Dual-NIC Design: Out-of-band monitoring architecture. Ensures log pipelines survive even when endpoint network segments are completely isolated during active containment.

OUR LAB ARCHITECTURE

- Network Design:



SOC Technology Stack



Sysmon v15

Granular process, network, and registry logging mapping activity directly to process command lines. Custom SwiftOnSecurity config deployed.



Wazuh FIM

Real-time file integrity monitoring active on all critical department shares in C:\Shares. Tracks read, write, and rename events.



Sliver C2

Simulated command-and-control framework mimicking Conti/Cobalt Strike operations and HTTPS beacon protocols.



Atomic Red Team

Framework for reproducing mapped techniques against our endpoint baselines in a highly structured sandbox environment.

PHASE 1: PREPARATION

THE TEAM & THE PLAYBOOK

-  **Salma Ali Mohamed (Team Lead):** Signs off on containment playbooks, authorizes emergency host isolation, and handles regulatory report structures.
-  **Youssef Sharqawy (IR Tier 2):** Investigates escalated alerts, hunts for hidden implants, and coordinates malware eradication on disk.
-  **Mohamed Atef (SOC Tier 1):** Continuously monitors dashboard triggers, filters noise, and escalates Level 15 alerts within minutes.

LEVEL 15 CRITICAL ALERT SLA

15 MINUTES TO ACT

No validation delay. No committee debates. Trigger immediate containment workflows when Level 15 fires.

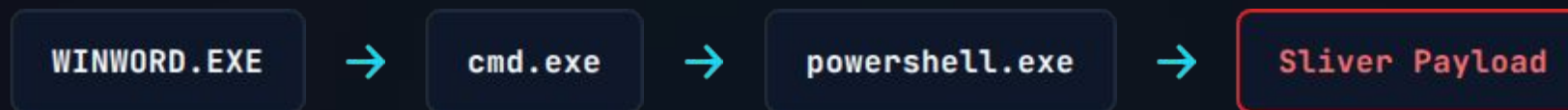
SOC Operations Pre-Attack Baseline

- ✓ Wazuh agents active and reporting on all target servers
- ✓ Sysmon v15 active on DC01, FS01, and WS-EMP01
- ✓ Sysmon event forwarding configured cleanly in ossec.conf

Active Baselines

You cannot compare an alert to a baseline that doesn't exist. HSE didn't have one. We did. That is why they were blind for 57 days, and why we spotted anomalies within minutes of execution.

| T+0: INITIAL ACCESS



✖ T1204.002 Execution

User opens a simulated malicious phishing attachment. Macros trigger automated command pipelines.

PowerShell invokes an obfuscated expression to connect back to 10.10.10.40.

Telemetry Highlights

```
Sysmon EID 1: ParentImage = WINWORD.EXE  
Sysmon EID 3: cmd.exe spawning network connection  
Detection Time: 90 seconds
```

| T+15: PERSISTENCE

🕒 T1053.005 Scheduled Task

To survive reboots, the attacker establishes a scheduled task.

They name the task **WindowsUpdateHelper** to masquerade as a legitimate operating system patching utility.

The task is pointed to: C:\Users\Public\invoice_Q3.exe

Wazuh Alerting Trace

```
Windows EID 4698: Task Created  
Wazuh Custom Rule 100030 triggered  
Severity: Level 12 (High)
```

Attackers hide behind familiar terminology. But task registry logs capture the exact binary source path every single time.

| T+30: C2 BEACONING

♥ Regular Traffic Patterns

The Sliver implant beacons out to the C2 address at 10.10.10.40:4444 every 30 seconds.

Dwell Identification: 49 identical outgoing hits captured on agent WS-EMPO1 within the analysis window.

The consistent interval signature stands out instantly against standard, irregular network baseline traffic.

Sysmon EID 3 Connections (30-Sec Intervals)



Heartbeat frequency fingerprinting confirms active C2 presence.

| T+60: CREDENTIAL DUMPING

LSASS Memory Access

The attacker launches Kiwi (Mimikatz) through the active Sliver session to harvest Domain Admin hashes.

They target lsass.exe to extract memory-cached passwords, session tokens, and NTLM credentials.

LEVEL 15 CRITICAL ALERT

```
Sysmon EID 10: Process Access  
Source: powershell.exe → Target: lsass.exe  
GrantedAccess: 0x1010  
Wazuh Custom Rule 100010: Triggered
```

Default configurations do not flag LSASS access at critical severity. Deployed Rule 100010 to eliminate this visibility gap.

T+90: LATERAL MOVEMENT

↔Pass-The-Hash pivoting

Using the harvested Domain Admin NTLM hash, the attacker authenticates across the domain with CrackMapExec.

They spawn remote WinRM administration sessions targeting FS01 and DC01.

Forensic Evidence Trace

```
Windows EID 4624 (FS01 & DC01): Successful Logon
Logon Type: 3 (Network)
Authentication Package: NTLM
Source IP: 10.10.10.40 (Not an Admin baseline host)
```

| T+120: DATA STAGING

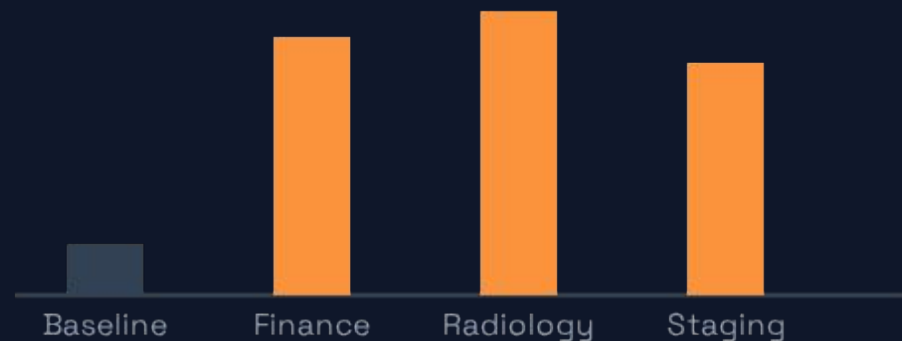
📁→ Department Share Harvest

The attacker logs into the file server FS01 via Evil-WinRM.

They recursively copy directories from all 4 primary shares (Finance, Radiology, Appointments, IT Support) to C:\Windows\Temp\stage and compile exfil.zip.

HSE lacked File Integrity Monitoring and remained completely blind during exfiltration staging. We configured Wazuh to track these events instantly.

FIM Access Burst Spike (Alerts / Sec)



| T+150: RANSOMWARE

Payload Detonation

The PowerShell AES encryption script runs against C:\RansomSimLab.

In less than 30 seconds, 100 critical document files are renamed to a .akira extension.

The ransom note HOW_TO_DECRYPT.txt is dropped recursively across directories.

FREQUENCY DETECTOR SPIKE

Wazuh FIM Engine logs rapid write activity.
Wazuh Custom Rule 100020 (Frequency) fires:
Trigger: >20 write operations in <30s
Severity: **Level 15 (Critical)**

Ransomware leaves an unmistakable fingerprint of high-speed modifications.

Our custom frequency rule caught it in 12 seconds.

CONTAINMENT: THE 15-MIN PLAYBOOK

♥ Automated and Active Defense

- ✓ Isolate **WS-EMP01**: Disable VMware NIC and block Tailscale to kill C2.
- ✓ Revoke Credentials: Disable emp01 user account in Active Directory.
- ✓ Block Attack Host: Block traffic from IP 10.10.10.40 at the SIEM boundary.
- ✓ Snapshot Host Memory: Snapshot volatile RAM before rebooting the server.
- ✓ Open Incident File: Document timestamps, file hashes, and network IoCs.

13 MIN

ELAPSED RESPONSE TIME

Eradicating without preserving volatile memory destroys malware sockets, registry hooks, and payload traces. Isolate first, analyze second.

PHASE 4: ERADICATION

```
# — DC01: CREDENTIAL ERADICATION (PowerShell – Domain Admin) —  
  
# Reset Domain Administrator password (invalidates all existing NTLM hashes)  
Set-ADAccountPassword -Identity Administrator -Reset \  
-NewPassword (ConvertTo-SecureString 'NewStr0ngP@ss2026!' -AsPlainText -Force)  
  
# Reset compromised user emp01 password  
Set-ADAccountPassword -Identity emp01 -Reset \  
-NewPassword (ConvertTo-SecureString 'EmpN3wS3cur3!2026' -AsPlainText -Force)  
  
# Re-enable emp01 account after password reset  
Enable-ADAccount -Identity emp01  
  
# Purge all Kerberos tickets across domain (forces re-auth with new credentials)  
Invoke-Command -ComputerName DC01,FS01,WS-EMP01 -ScriptBlock { klist purge }  
  
# Verify no rogue accounts created during attack window  
Get-ADUser -Filter * -Properties WhenCreated | \  
Where-Object { $_.WhenCreated -gt (Get-Date).AddDays(-7) } | \  
Select-Object Name, SamAccountName, WhenCreated
```



Active Directory Reset

Force password changes across Domain Admin accounts to invalidate captured NTLM hashes. Purge Kerberos tickets (klist) on all nodes to prevent persistent session hijack.



WS-EMP01 Cleanup

Kill process invoice_Q3.exe. Delete scheduled task WindowsUpdateHelper. Purge persistence keys in registry. Validate no open sockets remain on port 4444.



FS01 Remediation

Wipe C:\Windows\Temp\stage. Securely delete exfiltration archives. Audit file access logs for nested permissions. Confirm eradication of OSTap JavaScript payloads.

| PHASE 5: RECOVERY VALIDATION

✔ Clean-State Verification

- ✔ Wazuh agent status green on DC01, FS01, and WS-EMP01
- ✔ Rogue tasks and invoice_Q3.exe confirmed deleted
- ✔ Files shares restaged and restored via baseline backup
- ✔ Domain logins tested and validated using new rotated credentials
- ✔ No active connections detected pointing to 10.10.10.40

👁️ 72-Hour Elevated Monitor

HSE failed to monitor post-incident, leading to surviving backdoor implants reactivating weeks later. We established elevated 72-hour logging rules to flag any reactivation attempt instantly.

PHASE 6: LESSONS LEARNED

👍 What Worked

Sysmon + Wazuh: Complete visibility into process lines from a single dashboard.

FIM shares: Tracked both data staging and ransomware speed metrics in real-time.

Out-of-band SIEM: The Dual-NIC structure kept logging fully active during endpoint isolation.

⚠️ Gaps Mapped & Fixed

Default Gaps: Out-of-the-box SIEM filters did not treat LSASS access or FIM bursts as high-severity events.

IOC MASTER LIST

Indicator Type	Value	Phase Target	Action Actionable
IP Address	10.10.10.40	Network Control C2	Block on firewall / DNS Sinkhole
Port	4444	Backdoor Traffic	Audit router outbound access lists
File Name	invoice_Q3.exe	Initial Implant Execution	Kill process, blacklist hash
Process Parent	WINWORD.EXE → cmd.exe	Initial Execution	Quarantine parent process and spawn alert
Scheduled Task	WindowsUpdateHelper	Malicious Persistence	Remove task structure and payloads

MITRE ATT&CK MAPPING

Tactic Mapped	Technique ID	Simulated Threat Tool	Log Source
Initial Access	T1566.001	Phishing attachment (Word Document)	Sysmon EID 1
Execution	T1204.002	Microsoft Office automated macro invocation	Sysmon EID 1
Persistence	T1053.005	Scheduled Task (WindowsUpdateHelper)	Security EID 4698
Credential Access	T1003.001	LSASS Memory Access (Mimikatz)	Sysmon EID 10
Lateral Movement	T1021.002	CrackMapExec Pass-the-Hash	Security EID 4624
Collection & Impact	T1074.001 / T1486	PowerShell AES share encryption (Conti clone)	Wazuh FIM / Rule 100020

ANALYSIS COMPLETE · SYSTEM SECURED

Don't Wait for Day 57

Questions?

From **57 Days** of invisibility to **30 Minutes** of surgical detection. The HSE incident was a tragedy of architecture; the SpiderWizard Lab is a masterclass in **Control, Visibility, and Response.**

Project Lead: **Salma Ali**
Incident Lead: **Youssef Sharqawy**